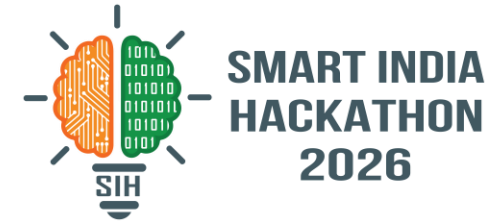
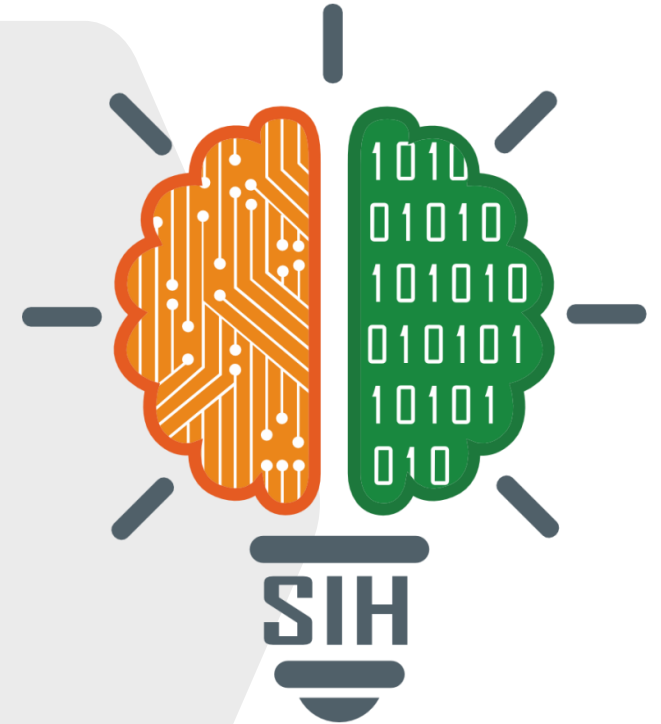


SMART INDIA HACKATHON 2026



- **Problem Statement ID – SIH26164**
- **Problem Statement Title – Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)**
- **Theme – Blockchain & Cybersecurity**
- **PS Category – Software**
- **Team ID – 139892**
- **Team Name – MetaD Bandits**



Why It Matters Now

Adversaries are harvesting encrypted data today to decrypt it when quantum computers arrive. India's DST roadmap sets **CII migration milestones for 2027–2029**, yet many teams cannot identify where RSA/ECC is used. Existing scanners provide a **flat CBOM list** without showing what needs attention first. **ECDAT turns discovery into decisions**: what is at risk first, what it costs to fix, and proof of what was checked.

Mosca's Law

$$X + Y > Z$$

X – Data-shelf time
Y – Migration Time
Z – Deadline

X – Data-shelf time

ARCHIVAL X~10 y
ballots, patient records
OPERATIONAL X~5 y
business databases
SHORT-TERM X~1.5 - 0 y
caches, session tokens

Y – Migration Time

5 years

4 years

2 years

Z – Deadline

12 years

10+5=15>12 → At Risk

10 years

5+4=9<10 → At Runtime

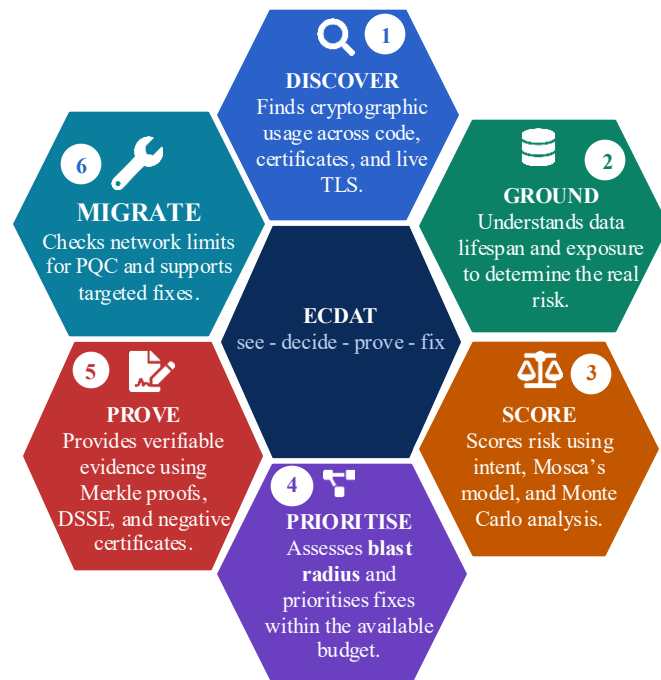
6 years

1.5+2=3.5>6 → At Runtime

Challenges & Problems

- Invisible Crypto:** Cryptographic algorithms can be hidden across **code, configurations, containers, certificates, and libraries**, making it difficult to maintain a complete inventory of where cryptography is being used.
- Guessed Data Lifespan:** Using the same **10-year lifespan** for every asset makes it difficult to accurately calculate Mosca's $X + Y > Z$ and determine which data needs earlier protection.
- Primitive Flooding:** A SHA-256 cache key can be flagged like **RSA protecting patient records**, creating too many alerts and making it harder to focus on real risks.
- Hidden Blast Radius:** A weak **root CA or shared library** can affect many downstream services, but thousands of findings may provide **no clear order for fixing them**.
- Unprovable Reports:** Unsigned JSON reports can be modified after scanning, so a claim such as **"100% scanned"** cannot be independently verified.
- PQC Size Shock:** ML-DSA-65 produces a 3,309 B signature (51.7 x ECDSA), which can exceed 64 B buffers and cause packets to be dropped on real networks.

Proposed Solution: The ECDAT Loop



Steps 1–6 directly address the six challenges on the left, with each step passing its result to the next.

Innovation & Uniqueness

Full-Stack Provenance

Combines findings from **code, libraries, configurations, certificates, and network handshakes** into one verifiable inventory.

Schema-to-Lifespan

Uses SQL DDL, Prisma, and ORM retention rules to **estimate data lifespan X automatically**, without spreadsheet-based guessing.

Intent-Aware Risk

DSIS identifies low-risk uses such as cache and ETag hashes, while **CAMS** estimates the effort needed for the required refactoring.

Blast-Radius-Aware Prioritisation

Uses **R₀ (blast radius)** to show how far a risk can spread, then prioritises fixes by **risk per developer-week** using the **Pareto frontier**.

Evidence-Graded Honesty

Uses **E0–E5 evidence levels**, an **Unknowns Ledger**, and signed certificates to clearly show what was checked and what was not.

Pre-Flight MTU Prober

Checks **ML-DSA-65** signature size against network limits and predicts **PQC packet drops** before deployment.

Methodology & Process

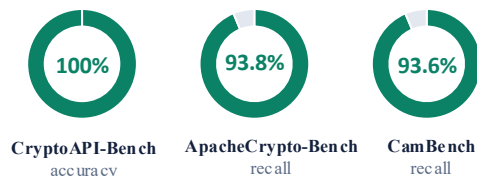
- Perimeter & Network Probe:** Defines the audit boundary, isolates binaries and keystores, and measures path MTU (1,500 B vs <1,280 B).
- Polyglot Discovery:** Scans JS/TS, Go, Rust, Java, Python, Ruby, configuration files, X.509 certificates, live TLS, and eBPF probes.
- Context Grounding:** Uses SQL/ORM data to estimate data lifespan X and checks Docker/Kubernetes configurations to assess exposure P(HNDL).
- Semantic Scoring:** Classifies intent (DSIS), agility (CAMS 0–3), and buffer hazards, then calculates Mosca Y-max using 5,000-run Monte Carlo analysis.
- Risk Spread & Data Lineage:** Maps the R_0 blast radius and traces data flow from entry to processing to exit (Ingress → Nexus → Egress).
- Pareto Optimisation:** Prioritises the highest risk-per-cost fixes within the developer-week budget and identifies the efficient frontier.
- Attest & Ship:** Creates a Merkle root, Ed25519 DSSE, and negative certificate, then generates CycloneDX, SARIF, CISO reports, and a CI gate.

Technology Stack



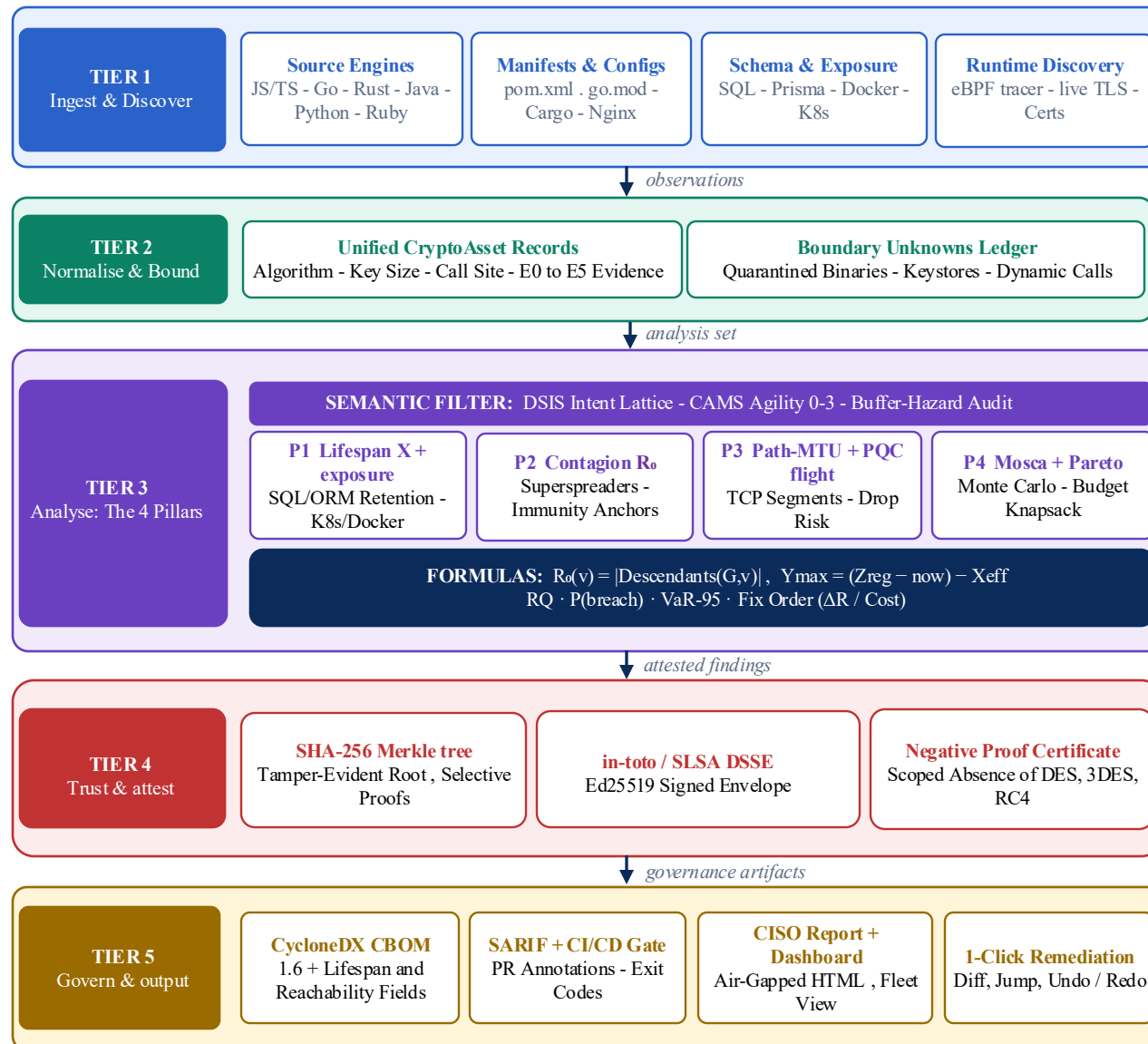
Pydantic - NetworkX - Pygments - Starlette - D3.js - KaTeX - WebCrypto

Proof of Work: 3 Public Benchmarks



2,810 files - 762 cases - 89/89 regression tests

System Architecture: 5 Tiers



FEASIBILITY AND VIABILITY

Technical Feasibility

Already Built: Our system is already implemented with a **10-stage pipeline** and **9 CLI commands** for scanning, checking, fixing, probing, and verification.

Benchmarked: It achieves **93.6–100%** results across **3 public suites**, and all **89/89 regression tests pass**.

Standards-Native: The system follows established standards: **FIPS 203/204/205**, **CycloneDX**, **SARIF 2.1.0**, and **in-toto / DSSE**.

Operational Feasibility

CI-Native: ecdat gate returns **exit code 0 / 1** and adds **SARIF pull-request annotations**.

Zero-Network Mode: Generates a **single-file, air-gapped report.html** for **isolated enclaves**.

Safe by Default: Uses **dry-run diff**, **SHA-256 checks**, **undo / redo journal**, and **protected targets** to prevent unsafe changes.

Financial Feasibility

Near-Zero Licence Cost: Uses an **open-source Python stack** and can run on a **laptop or existing CI runner**, reducing software costs.

Public Funding Fit: DST/NQM provides financial assistance opportunities for **indigenous solutions** progressing toward **TRL-9 pilots**.

Lean Pilot Budget: **CI runner + hosting costs** can be kept minimal during the pilot phase.

Social & Market Viability

Policy Tailwind: DST/NQM plans to require **vendor CBOMs from FY 2027–28** and supports **automated crypto-discovery tools** for vendor compliance.

Preparedness Gap: India's **BFSI leaders rate PQC readiness at 2.4 / 5**, showing a need for better PQC preparation.

Atmanirbhar Fit: **Indigenous quantum-safe tools** can benefit from preferential market access.

Challenge / Risk

Static analysis has limits due to Rice's theorem and hidden algorithms in dynamic reflection.

Precision can fall on messy production code (65.9% on the Apache corpus).

Auto-patching may break ciphertext compatibility.

Quantum arrival year is uncertain.

Opaque binaries, HSMs and third-party libraries may hide cryptographic usage.

Enterprise trust and adoption can be difficult.

Our Strategy

→ **E0–E5 evidence grading + Unknowns Ledger** to track uncertain findings and avoid missing anything.

→ **Dead-branch pruning + inter-procedural tracing** to improve precision; unclear flows go to **human review**.

→ **Dry-run diff + SHA-256 pre/post check + atomic write + undo/redo journal + protected-target fence** for safer changes.

→ **5,000-run Monte Carlo** using GRI-calibrated distributions to report **P(breach)** and **VaR-95** instead of one fixed date.

→ **Boundary Ledger + certificate/keystore scan + live TLS probe** to identify hidden cryptographic usage.

→ **Open-standard outputs + CI-native flow + offline dashboard** so source code stays within the network.

Rollout Aligned to India's DST / NQM Milestones

1 FOUNDATIONS

CII 2027 | Enterprises 2028

Discover & inventory:

- Signed **CycloneDX CBOM** for each repository.
- **Unknowns Ledger** for anything that cannot be fully inspected.
- Supports asset-repository and vendor-CBOM requirements.

2 HIGH-PRIORITY MIGRATION

CII 2028 | Enterprises 2030

Prioritise & migrate:

- Budget-fit sprint plan.
- MTU-safe **ML-KEM / ML-DSA** target.
- **1-click fixes** for priority systems.

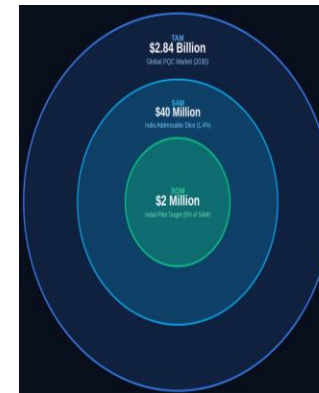
3 FULL PQC ADOPTION

CII 2029 | Enterprises 2033

Prove & monitor:

- Negative certificates.
- Fleet scorecard.
- CI gate that blocks new classical-only deployments.

Market Sizing & Sources



TAM ~ USD 2.84 B (2030): Global Pqc Quantum Cryptography market forecast by MarketsandMarkets, growing from **USD 0.42 B in 2025 at 46.2% CAGR**.

SAM ~ USD 40 M (2030): Derived estimate using **TAM × 1.4%**, based on India's share of global information-security spending.

SOM ~ USD 2 M (2030): Based on a **5% share of the estimated USD 40 M SAM** → **USD 40 M × 5% = USD 2 M**.

TAM includes hardware, VPN and libraries; ECDAT targets the discovery and migration-planning segment, which is not separately sized by the cited market report.

IMPACT AND BENEFITS



 References

- 1 NIST FIPS 203 / 204 / 205: ML-KEM, ML-DSA, SLH-DSA (Aug 2024).
- 2 NIST IR 8547 (initial public draft, Nov 2024): Transition to Post-Quantum Cryptography Standards.
- 3 OMB Memorandum M-26-15: Execution of the Migration to Post-Quantum Cryptography (24 Jun 2026).
- 4 DST / National Quantum Mission: Quantum-Safe Ecosystem in India, Roadmap to Quantum Resiliency (May 2026).
- 5 Global Risk Institute and evolutionQ: Quantum Threat Timeline Report 2025 (Mosca and Piani, 2026).
- 6 M. Mosca: Cybersecurity in an Era with Quantum Computers: Will We Be Ready? IEEE Security & Privacy 16(5), 2018.
- 7 OWASP CycloneDX (ECMA-424): CBOM and Attestations (CDXA); community discussion #966 on PQC compliance.
- 8 in-toto Attestation Framework, DSSE (Secure Systems Lab) and SLSA supply-chain levels.
- 9 OASIS: Static Analysis Results Interchange Format (SARIF) v2.1.0.
- 10 IETF RFC 8879: TLS Certificate Compression.
- 11 Afrose, Rahaman, Yao: CryptoAPI-Bench, IEEE SecDev 2019.
- 12 Afrose et al.: Evaluation of Static Vulnerability Detection Tools with Java Cryptographic API Benchmarks (ApacheCryptoAPI-Bench), IEEE TSE 2023.
- 13 Wickert et al.: CamBench, Mining Software Repositories (MSR) 2022.
- 14 MarketsandMarkets: Post-Quantum Cryptography Market (Oct 2025); Gartner information-security spending forecasts (Jul 2025, Mar 2026).
- 15 IBM: Cost of a Data Breach Report 2025 (as cited in the DST report).

 Try It / See ItGITHUB : [ECDAT](#)